Oski Lab

1. Kịch bản

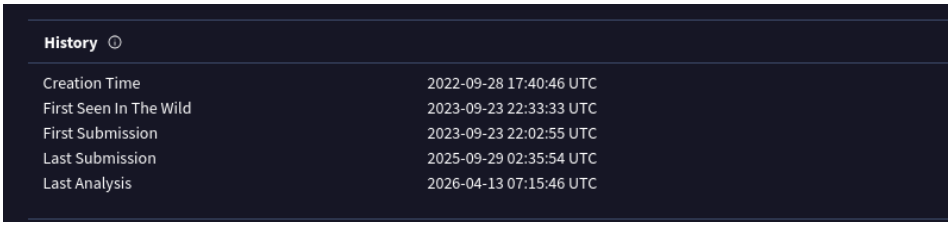
- Kế toán nhận được email với tiêu đề “Urgent New Order” từ client. Khi truy cập hóa đơn đính kèm thì thông tin order sai. Sau đó, SIEM tạo alert cảnh báo tải xuống file đáng ngờ. Theo điều tra PPT file có thể là nguyên nhân việc tải xuống này. Hãy phân tích chi tiết file này

2. Write up

1. Determining the creation time of the malware can provide insights into its origin. What was the time of malware creation?

- Yêu cầu: tìm thời gian tạo malware để truy nguồn gốc
  - Là mới tạo hay là mối đe dọa cũ tái xuất
  - Thời gian tạo với phát hiện cách nhau thế nào → khả năng lẩn tránh
- As: 2022-09-28 17:40
- Thu được thông tin malware, lấy mã hash tra trên https://www.virustotal.com/

- Thông tin về lịch sử malware



History

Creation Time	2022-09-28 17:40:46 UTC
First Seen In The Wild	2023-09-23 22:33:33 UTC
First Submission	2023-09-23 22:02:55 UTC
Last Submission	2025-09-29 02:35:54 UTC
Last Analysis	2026-04-13 07:15:46 UTC

2. Identifying the command and control (C2) server that the malware communicates with can help trace back to the attacker. Which C2 server does

the malware in the PPT file communicate with?

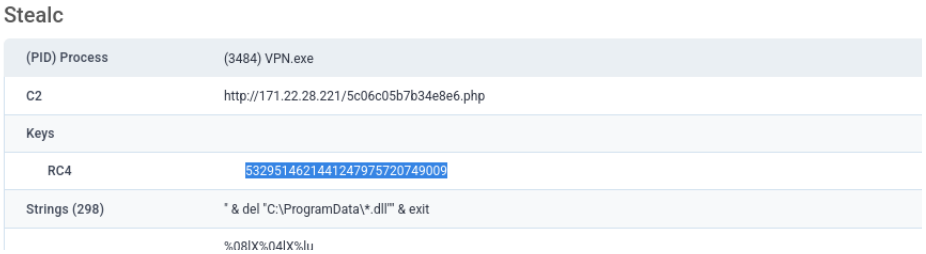
- Yêu cầu: Xác định C2 server giúp truy vết hacker
- As: http://171.22.28.221/5c06c05b7b34e8e6.php
- Nó là dạng file để có hàm xử lý dữ liệu, tương tác đến nó giống như traffic bình thường

3. Identifying the initial actions of the malware post-infection can provide insights into its primary objectives. What is the first library that the malware requests post-infection?

- Yêu cầu: Phân tích các hành vi ban đầu sau xâm nhập → mục đích malware
- As: sqlite3.dll
- sqlite3.dll: cung cấp bộ máy tương tác tệp cơ sở dữ liệu (.db, .sqlite)
    - Malware thường dùng để kết nối vào database trình duyệt để truy xuất thông tin

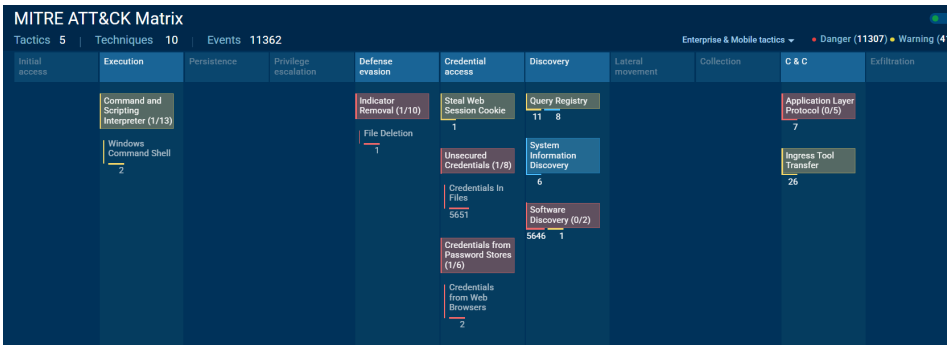
4. By examining the provided Any.run report, what RC4 key is used by the malware to decrypt its base64-encoded string?

- As: 53295146214412479757207490 09
- RC4: mã hóa dòng khóa đối xứng với kích thước khóa thay đổi



5. By examining the MITRE ATT&CK techniques displayed in the Any.run sandbox report, identify the main MITRE technique (not sub-techniques) the malware uses to steal the user's password.

- Yêu cầu: xác định MITRE chính mà malware dùng để đánh cắp password người dùng
- As: T1555
- Khung MITRE ATTCK xuất hiện T1555 có liên quan đến password



Thông tin đăng nhập từ kho lưu trữ mật khẩu

Các kỹ thuật phụ (6)

Kẻ thù có thể tìm kiếm các vị trí lưu trữ mật khẩu phổ biến để lấy thông tin đăng nhập của người dùng. [1] Mật khẩu được lưu trữ ở nhiều nơi trên hệ thống, tùy thuộc vào hệ điều hành hoặc ứng dụng lưu giữ thông tin đăng nhập. Cũng có các ứng dụng và dịch vụ cụ thể lưu trữ mật khẩu để giúp người dùng dễ dàng quản lý và duy trì chúng hơn, chẳng hạn như trình quản lý mật khẩu và kho bí mật đám mây. Sau khi có được thông tin đăng nhập, chúng có thể được sử dụng để di chuyển ngang và truy cập thông tin bị hạn chế.

ID: T1555

Các kỹ thuật phụ: T1555.001 , T1555.002 , T1555.003 , T1555.004 , T1555.005 , T1555.006

Chiến thuật: Truy cập bằng thông tin xác thực

Nền tảng: IaaS, Linux, Windows, macOS

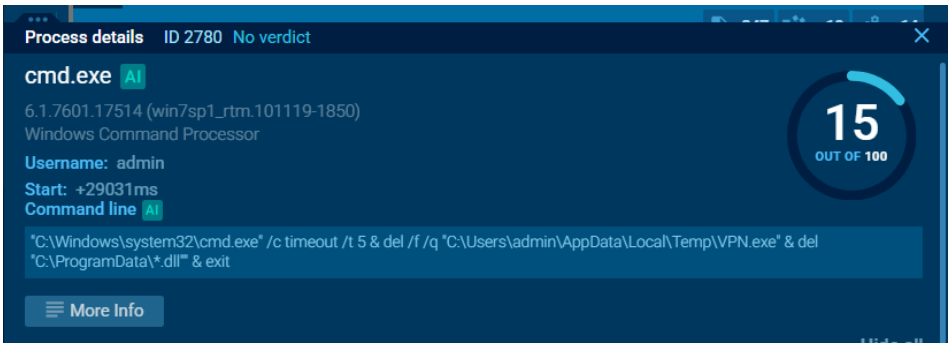
Phiên bản: 1.2

Ngày tạo: 11 tháng 2 năm 2020

Cập nhật lần cuối: 24 tháng 10 năm 2025

6. By examining the child processes displayed in the Any.run sandbox report, which directory does the malware target for the deletion of all **DLL** files?

- Yêu cầu: dựa vào tiến trình, tìm thư mục malware muốn xóa tất cả DLL
- As: C:\ProgramData
- Malware thông qua cmd thực hiện lệnh xóa file VPN.exe và tất cả DLL. Đây có thể là dấu hiệu xóa dấu vết



7. Understanding the malware's behavior post-data exfiltration can give insights into its evasion techniques. By analyzing the child processes, after successfully exfiltrating the user's data, **how many seconds does** it take for the malware to **self-delete**?

- Yêu cầu: phân tích hành vi malware sau khi lấy được data để hiểu kỹ thuật né tránh
- As: 5
- Tự xóa 5s sau thực thi → Self-deletion

3. Mitre ATTCK

1. **Initial Access**

- T1566.001: **Phishing: Spearphishing Attachment**
  - Dùng email đính kèm file độc hại dựa vào việc thực thi của người dùng để giành quyền thực thi

2. **Execution**

- T1204.002: **User Execution: Malicious File**
  - Dựa vào việc người dùng mở tệp độc hại để thực thi
- T1059.003: **Command and Scripting Interpreter: Windows Command Shell**
  - Lợi dụng cmd thực thi lệnh và phần mềm độc hại

3. **Defense Evasion**

- T1140: **Deobfuscate/Decode Files or Information**
  - T1027.013: **Obfuscated Files or Information: Encrypted/Encoded File**

        - Mã hóa strings trong file để cản trở phát hiện
    - Sau khi mã hóa → dùng T1140: giải mã thông tin
- T1070.004: **Indicator Removal: File Deletion**
    - Xóa file, công cụ, tập tin hacker cài đặt hoặc tạo ra khỏi hệ thống để xóa dấu vết

4. **Credential Access**

- T1555.003: **Credentials from Password Stores: Credentials from Web Browsers**
    - Trình duyệt thường lưu in4 đăng nhập (thường mã hóa) → tìm trong kho lưu trữ

5. **Command and Control**

- T1071.001: **Application Layer Protocol: Web Protocols**
    - Lạm dụng giao thức HTTP/S để hòa lẫn vào lưu lượng hiện có

6. **Exfiltration**

- T1041: **Exfiltration Over C2 Channel**
    - Sử dụng kênh C2 để gửi data (thường cùng giao thức với kênh C2)